

Controls and compliance checklist

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☒	☐	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☒	☐	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☒	☐	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.

- | | | |
|-------------------------------------|--------------------------|--|
| ☒ | ☐ | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| ☒ | ☐ | Data is available to individuals authorized to access it. |
-

Recommendations :

- 1. Enforce Least Privilege: Review and restrict employee access levels to ensure that users only have access to data strictly necessary for their specific job functions.**
- 2. Establish a Disaster Recovery & Business Continuity Plan: Create a well-structured, easy-to-understand strategy to guarantee rapid business recovery in the event of a disaster or major incident.**
- 3. Implement Separation of Duties: Divide critical tasks among different employees to prevent conflicts of interest (e.g., ensuring the person who processes payroll/invoices is not the same person authorized to execute the payments).**
- 4. Deploy an Intrusion Detection System (IDS): Implement an IDS to continuously monitor internal network traffic and verify security logs for unauthorized or malicious activity.**
- 5. Upgrade Password Security & Management: Enforce modern complexity requirements (minimum character counts, special characters, and numbers). Implement a secure, centralized cloud password manager restricted to authorized IT personnel to prevent credential loss, streamline resets, and save IT department resources.**

- 6. Implement Secure Off-Site Backups:** Establish a regular backup schedule and ensure copies are stored securely outside the main network infrastructure (e.g., an isolated backup server or secure cloud) to protect against ransomware or network-wide breaches.
- 7. Schedule Legacy System Maintenance:** Define a periodic, documented schedule for the monitoring and maintenance of end-of-life legacy systems to establish clear, standardized intervention methods.
- 8. Enforce Data Encryption:** Implement robust encryption mechanisms to secure sensitive customer data, including credit card details, transactions, and processing logs, both at rest and in transit.